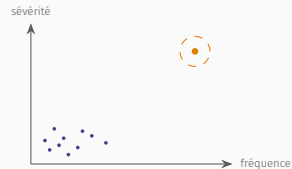


Risque opérationnel et résilience

Chapitre 1 : Introduction au risque opérationnel et à la résilience



Où en sommes-nous ?

Définir le risque opérationnel

Les origines et les frontières du risque opérationnel

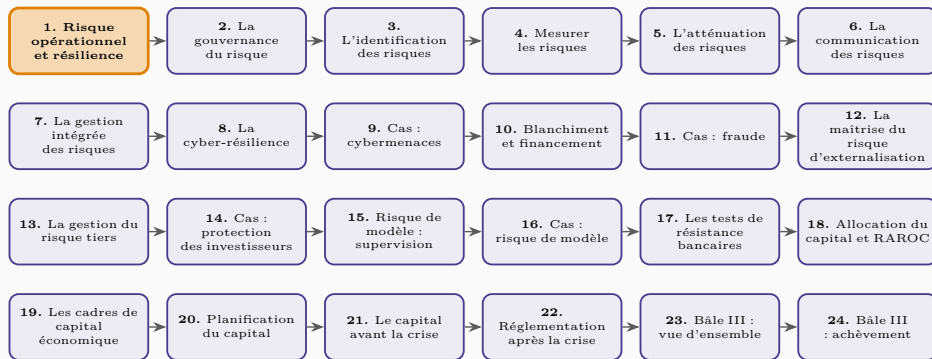
Les cadres de gestion du risque opérationnel

La nature du risque opérationnel

La résilience opérationnelle

Synthèse

Où en sommes-nous?



Pourquoi ce chapitre ?

Ce premier chapitre ouvre le cours en posant la définition du risque opérationnel, sa taxonomie de référence, ses frontières avec les risques de conformité, de réputation et stratégique, et le cadre général de sa gestion. Il introduit également la notion de résilience opérationnelle, complément plus récent du risque opérationnel dans le paysage réglementaire.

Définir le risque opérationnel

La définition du Comité de Bâle

Le Comité de Bâle sur le contrôle bancaire (BCBS) définit le risque opérationnel comme le risque de perte résultant de processus internes, de personnes ou de systèmes inadéquats ou défaillants, ou d'événements externes. Cette définition porte sur les **causes** du risque opérationnel — personnes, processus, systèmes, événements externes — non sur ses conséquences, qui peuvent être financières, opérationnelles, ou les deux.

Des causes non financières, à la différence des autres risques

Contrairement au risque de marché, au risque de liquidité et, dans une certaine mesure, au risque de crédit, les causes du risque opérationnel sont typiquement non financières par nature. C'est cette spécificité qui a longtemps rendu le risque opérationnel difficile à intégrer dans les cadres de gestion des risques financiers traditionnels.

Les sept catégories d'événements de Bâle

Une taxonomie en sept catégories de niveau 1

Le BCBS répartit le risque opérationnel en sept catégories principales, dites « types Bâle » : la fraude interne, la fraude externe, les pratiques d'emploi et sécurité du travail, les clients/produits/pratiques commerciales, les dommages aux actifs physiques, l'interruption d'activité et les dysfonctionnements des systèmes, et enfin l'exécution, la livraison et la gestion des processus. Ces sept catégories sont ensuite subdivisées en catégories de niveau 2, elles-mêmes illustrées par des exemples de niveau 3.

Une répartition très inégale entre fréquence et sévérité

Les données de pertes de l'industrie (base ORX, 2014-2019) montrent que 75 % de la fréquence des événements se concentre sur quatre catégories, mais que deux catégories seulement — clients/produits/pratiques commerciales, et exécution/livraison/gestion des processus — expliquent 79 % de la sévérité totale (86 % en ajoutant la fraude externe). La catégorie clients/produits/pratiques commerciales représente plus de la moitié des pertes pour moins d'un quart de la fréquence, en raison notamment des amendes réglementaires, parfois de plusieurs milliards de dollars, qu'elle inclut.

Quelques incidents emblématiques

Bank of America a payé 16,7 milliards USD d'amende en 2014 pour la vente de titres adossés à des créances hypothécaires avant la crise financière — 82,7 milliards USD d'amendes cumulées depuis 2000. Equifax a mis deux mois à révéler un piratage touchant les données de 145 millions de clients, perdant 3,5 milliards USD de capitalisation boursière. La défaillance de migration informatique de TSB Bank en 2018 a privé d'accès des dizaines de milliers de clients pendant plusieurs semaines. Jérôme Kerviel a généré 4,9 milliards d'euros de pertes de trading non autorisé chez Société Générale en 2008.

Les origines et les frontières du risque opérationnel

De Barings à la RPSMOR

Contrairement au risque de crédit ou de marché, gérés depuis des siècles, le risque opérationnel est une discipline récente, née dans les années 1990. La faillite de la banque Barings en 1995, provoquée par les pertes de 660 millions de livres du trader Nick Leeson à Singapour, a servi de catalyseur réglementaire : le BCBS en a tiré les leçons pour développer les exigences de gestion du risque opérationnel, aujourd'hui codifiées dans les Principes pour la saine gestion du risque opérationnel (RPSMOR), révisés en 2021.

Des frontières discutées

La définition du BCBS inclut le risque légal (lié à l'exécution ou à la rupture de contrats) mais exclut explicitement les risques stratégique et réputationnel — une exclusion motivée par le souci de garder la mesure du risque opérationnel aussi objective que possible. En pratique, la plupart des organisations financières incluent néanmoins l'évaluation et la gestion du risque réputationnel dans leurs activités de gestion du risque opérationnel.

Le risque stratégique mal exécuté est un risque opérationnel

La distinction est subtile : le risque de faire un mauvais choix stratégique diffère du risque d'exécuter maladroitement une stratégie par ailleurs saine. Ce second cas — mauvaise exécution due à des processus, des personnes ou des systèmes inadéquats — relève bien du risque opérationnel, même lorsqu'il se manifeste au niveau du conseil d'administration.

Les cadres de gestion du risque opérationnel

ISO 31000 et COSO ERM

Les établissements financiers s'inspirent des cadres de management global des risques (ERM) les plus répandus — la norme internationale ISO 31000 (révisée en 2018 pour mettre l'accent sur la création de valeur) et le référentiel COSO ERM — pour construire leur propre cadre de gestion du risque opérationnel (ORMF).

Le cycle de gestion des risques en quatre étapes

Identification, évaluation, atténuation, surveillance

Quelle que soit sa représentation graphique, un cadre de gestion des risques se ramène à quatre activités : l'**identification** des risques (chapitre 3), leur **évaluation** en termes de probabilité et d'impact (chapitre 4), leur **atténuation** par des contrôles ou d'autres mesures (chapitre 5), et leur **surveillance** continue, qui referme le cycle en réinjectant les enseignements dans la prochaine identification.

Gouvernance, culture et appétit pour le risque comme piliers transversaux

Un cadre de gestion du risque opérationnel plus complet ajoute au cycle en quatre étapes des blocs transversaux : la gouvernance du risque (répartition des rôles et responsabilités), la culture et la conduite du risque, et l'appétit pour le risque — trois éléments détaillés au chapitre 2.

La nature du risque opérationnel

Cinq caractéristiques structurantes

Hétérogène, idiosyncratique, à queue épaisse, interconnecté, dynamique

Le risque opérationnel présente cinq traits qui compliquent sa gestion et sa modélisation. Il est **hétérogène** : même au sein d'une catégorie, les événements diffèrent fortement (vol de carte bancaire contre rançongiciel). Il est **idiosyncratique** : sa matérialisation dépend fortement de la capacité et de la volonté de chaque organisation à le gérer. Il est à **queue épaisse** : une multitude de petites pertes coexistent avec un petit nombre de pertes extrêmes, plusieurs ordres de grandeur au-dessus de la médiane. Il est **interconnecté** avec les autres risques via des « événements frontières » — un risque de marché ou de crédit dont la cause est en réalité opérationnelle. Il est enfin **dynamique** : sa nature évolue avec celle de l'activité et de l'environnement de l'organisation.

Tout le monde est gestionnaire du risque

Parce que le risque opérationnel naît de chaque personne et de chaque processus de l'organisation, il ne peut pas être centralisé comme le risque de crédit ou de marché. La formule consacrée dans la discipline est que « tout le monde est un gestionnaire du risque » : la fonction centrale de gestion du risque opérationnel coordonne le reporting et l'information, mais l'atténuation du risque relève de chaque employé.

La résilience opérationnelle

Un complément récent au risque opérationnel

Prévenir, s'adapter, répondre, se rétablir, apprendre

La résilience opérationnelle désigne la capacité des établissements et du secteur financier dans son ensemble à prévenir, s'adapter, répondre, se rétablir et apprendre des perturbations opérationnelles. Elle s'est imposée à la fin des années 2010, sous l'effet de la dépendance croissante du secteur financier aux systèmes informatiques et aux prestataires tiers critiques, puis a été renforcée par la pandémie de COVID-19.

Le Royaume-Uni, précurseur réglementaire

Les régulateurs britanniques (FCA, PRA, Banque d'Angleterre) ont été les premiers à publier, en 2018, un cadre de résilience opérationnelle articulé autour des « services opérationnels importants » — dont la perturbation causerait un préjudice intolérable aux clients ou à l'intégrité du marché — et de « niveaux de tolérance à l'impact ». Cette approche par les services, plutôt que par les processus, constitue l'innovation principale de la démarche britannique, reprise ensuite par la Réserve fédérale américaine (2020) et par le BCBS (2021).

Les sept principes de résilience du BCBS

Le BCBS a publié en mars 2021 ses Principes pour la résilience opérationnelle, structurés autour de sept axes : gouvernance ; gestion du risque opérationnel ; planification et tests de continuité d'activité ; cartographie des interconnexions et interdépendances ; gestion de la dépendance aux tiers ; gestion des incidents ; et résilience des technologies de l'information et de la communication, y compris la cybersécurité.

La résilience est un résultat, pas un dispositif séparé

Le BCBS est explicite : « la résilience opérationnelle est un résultat qui bénéficie d'une gestion efficace du risque opérationnel. » Autrement dit, la résilience ne remplace pas le cadre de gestion du risque opérationnel — elle en est la conséquence directe lorsque ce cadre fonctionne bien.

Synthèse

Synthèse du chapitre

Le risque opérationnel se définit par ses causes — personnes, processus, systèmes, événements externes — réparties en sept catégories de niveau 1 par le BCBS, dont deux (clients/produits/pratiques commerciales, et exécution/livraison/gestion des processus) concentrent l'essentiel de la sévérité. Ses frontières avec les risques légal, de conformité, réputationnel et stratégique restent débattues, mais sa gestion suit un cycle universel — identification, évaluation, atténuation, surveillance — porté par une gouvernance, une culture et un appétit pour le risque adaptés. Ses cinq traits distinctifs (hétérogène, idiosyncratique, à queue épaisse, interconnecté, dynamique) expliquent pourquoi il ne peut être géré de manière centralisée, contrairement aux risques de marché ou de crédit. La résilience opérationnelle, apparue à la fin des années 2010 et consacrée par les sept principes du BCBS en 2021, en est le prolongement naturel : elle ne se substitue pas à une bonne gestion du risque opérationnel, elle en découle.